Protocolo de Ciberseguridad

Sistema de Gestión de Recursos y Soporte de Informática (SGRSI) — Instituto Tecnológico de Informática (ITI)

1. Objetivo del protocolo

Este protocolo establece los aspectos de seguridad que la empresa u organización contratante (en este caso, el ITI) debe tener en cuenta durante el desarrollo, la implementación y la operación del SGRSI, así como las reglas mínimas obligatorias que el sistema debe cumplir para proteger la confidencialidad, integridad y disponibilidad de la información gestionada.

2. Alcance

Aplica a todos los módulos del SGRSI (gestión de usuarios, incidencias, recursos tecnológicos, préstamos y reportes), a la infraestructura sobre la que se despliega (servidor institucional, contenedores Docker, base de datos MySQL) y a todos los roles de usuario definidos: Administrador/Coordinador, Técnico/Soporte y Solicitante.

3. Aspectos a cuidar

El protocolo se organiza en torno a los siguientes pilares de seguridad de la información:

- Confidencialidad: que solo los usuarios autorizados accedan a los datos de usuarios, equipos, tickets e historiales.
- Integridad: que los datos registrados (préstamos, diagnósticos, soluciones, estados de ticket) no puedan ser alterados de forma indebida o inconsistente.
- Disponibilidad: que el sistema permanezca operativo durante el horario institucional y que exista una estrategia de recuperación ante fallos.
- Trazabilidad: que toda acción crítica quede registrada, identificando quién la realizó y cuándo.
- Control de acceso: que cada usuario solo pueda ejecutar las funciones correspondientes a su rol.
- Continuidad operativa: que existan respaldos y un entorno reproducible (contenedores) que permitan restablecer el servicio ante una incidencia.

4. Reglas que no pueden faltar

Independientemente del alcance final del desarrollo, las siguientes reglas se consideran mínimas y no negociables para el SGRSI:

- Ningún dato sensible (contraseñas, datos personales) se almacena o transmite en texto plano.
- Ninguna consulta a la base de datos se construye concatenando entradas del usuario.

• Ninguna función del sistema se ejecuta sin verificar previamente el rol del usuario autenticado.

• Toda acción crítica queda registrada en un historial de auditoría.

• El sistema no es accesible desde redes públicas, solo desde la red institucional.

• Existen copias de seguridad periódicas, almacenadas fuera del servidor principal.

5. Detalle de reglas y funcionamiento en el sistema

La siguiente tabla detalla cada regla, el riesgo que mitiga y su implementación concreta dentro del SGRSI.

ID	Regla	Qué protege / riesgo que mitiga	Cómo funciona en el SGRSI
CS-01	Autenticación obligatoria	Accesos no autorizados a datos institucionales	Todo acceso a los módulos requiere inicio de sesión con correo y contraseña (DM-21). Sin sesión activa, el sistema redirige al formulario de login.
CS-02	Contraseñas con hash seguro	Robo o filtración de contraseñas	Las contraseñas se almacenan únicamente como hash irreversible generado con password_hash() y el algoritmo PASSWORD_BCRYPT; nunca se guardan en texto plano.
CS-03	Regeneración de sesión tras login	Fijación de sesión (session fixation)	Al autenticarse correctamente, el sistema genera un nuevo identificador de sesión, invalidando cualquier ID previo que un atacante pudiera conocer.
CS-04	Control de acceso basado en roles (RBAC)	Uso de funciones fuera del rol autorizado	Cada acción valida en el servidor el rol del usuario (Administrador/Coordinador, Técnico/Soporte, Solicitante) antes de ejecutarse; el menú además oculta las opciones no autorizadas.
CS-05	Consultas preparadas (prepared statements)	Inyección SQL	Todas las consultas a MySQL se arman con parámetros vinculados. No se concatenan datos ingresados por el usuario dentro de sentencias SQL.

CS-06	Validación en cliente y en servidor	Ingreso de datos maliciosos o inconsistentes	JavaScript valida en el navegador para mejorar la experiencia, pero PHP revalida siempre en el servidor, ya que la validación del cliente puede evadirse fácilmente.
CS-07	Token CSRF en formularios	Peticiones falsificadas entre sitios (CSRF)	Cada formulario que modifica datos incluye un token único vinculado a la sesión del usuario, verificado por el servidor antes de procesar la operación.
CS-08	Registro de auditoría de acciones	Falta de trazabilidad ante incidentes	El sistema registra automáticamente usuario, fecha y hora de cada acción crítica: altas/bajas de usuarios, modificación de activos y cambios de estado de tickets (DM-25).
CS-09	Copias de seguridad periódicas	Pérdida de información ante fallos o ataques	Scripts en Bash ejecutan backups automáticos de la base de datos MySQL, almacenados en una ubicación distinta al servidor principal, con verificación de integridad.
CS-10	Restricción a la red institucional	Exposición del sistema a redes públicas	El SGRSI opera únicamente dentro de la intranet del ITI, desplegado con docker-compose, sin publicar puertos hacia redes externas.
CS-11	Cierre de sesión y expiración por inactividad	Sesiones abiertas en equipos compartidos de laboratorio	El usuario puede cerrar sesión manualmente (DM-22); se recomienda además definir un tiempo de inactividad tras el cual la sesión expire automáticamente.
CS-12	Principio de mínimo privilegio	Escalamiento de privilegios	Cada rol accede únicamente a las funciones necesarias para su tarea. Los permisos se revisan al dar de alta o modificar un usuario (DM-01, DM-02).
CS-13	Manejo seguro de errores	Fuga de información técnica (rutas, consultas, versiones)	Ante un fallo, el sistema muestra mensajes claros orientados al usuario final, sin exponer detalles internos del backend o la base de datos.

CS-14	Versión fija de la imagen del contenedor	Vulnerabilidades conocidas en dependencias desactualizadas	La imagen base de la aplicación (por ejemplo php:8.2-apache) se fija a una versión específica y se actualiza de forma planificada, evitando ejecutar versiones sin parches conocidos.

6. Responsabilidades

• Equipo de desarrollo: implementar las reglas técnicas (CS-01 a CS-09, CS-13, CS-14) en el código y la infraestructura.

• Administrador/Coordinador del ITI: gestionar altas, bajas y roles de usuario respetando el principio de mínimo privilegio (CS-04, CS-12).

• Institución (ITI): garantizar que el servidor y la red institucional cumplan con la restricción de acceso exclusivo a la intranet (CS-10) y disponer de un lugar seguro para almacenar los backups (CS-09).